The Boogeyman 3 (Finale)

Incident Investigation Summary

Incident ID: SOC-IR-2026-BOOGEYMAN3
Severity: CRITICAL
Investigation Date: April 27, 2026
Security Analyst: Badr Naji

1. Executive Summary

A targeted phishing campaign against Quick Logistics LLC's CEO, Evan Hutchinson, led to a full domain compromise. The attacker used an ISO file mounted as a virtual drive (D:) containing an HTA payload executed via `mshta.exe`. This initial access resulted in persistence (scheduled task), privilege escalation (UAC bypass via `fodhelper.exe`), credential dumping (Mimikatz), lateral movement to a workstation and the domain controller, DCSync attacks, and finally deployment of ransomware across multiple hosts. The attack was detected via Elastic Stack logs (Sysmon and Windows Event Logs) and fully reconstructed.

2. Timeline of Key Events

Timestamp	Event Description
Aug 29, 23:51:15	`mshta.exe` (PID 6392) executed `D:\ProjectFinancialSummary_Q3.pdf.hta` – initial stage 1 payload.
Aug 29, 23:51:16	`xcopy.exe` copied `review.dat` from D: to `C:\Users\EVAN~1.HUT\AppData\Local\Temp\review.dat`.

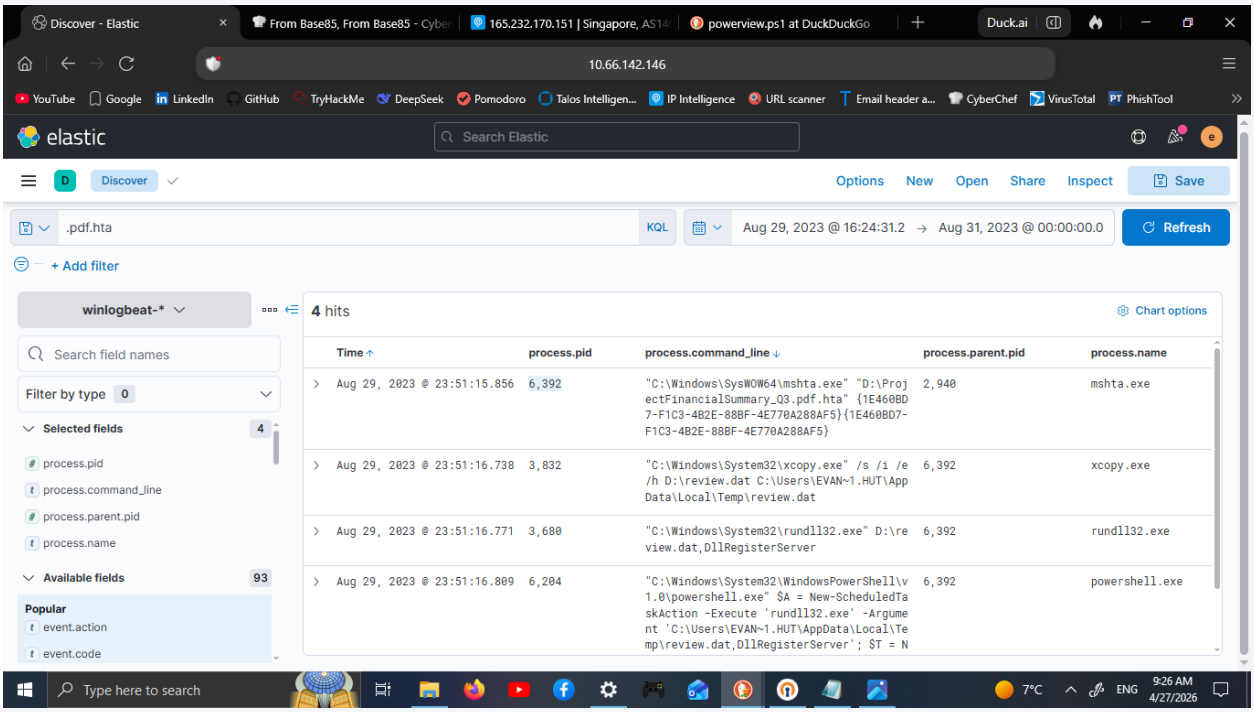
Timestamp	Event Description
Aug 29, 23:51:16	`rundll32.exe` executed the copied `review.dat` as a DLL entry point.
Aug 29, 23:51:16	PowerShell created a scheduled task named `Review` to run `rundll32.exe` with the same DLL daily at 06:00.
Aug 29, 23:54:49	`fodhelper.exe` executed (UAC bypass) launching an encoded PowerShell payload.
Aug 29, 23:54:49	DNS query to `cdn.bananapeelparty.net` resolved to `165.232.170.151:80` (C2).
Aug 29, 23:55:17	`whoami /all` executed for recon.
Aug 30, 00:06–00:09	PowerView scripts downloaded; domain discovery (`Get-DomainComputer`, `Get-DomainUser`).
Aug 30, 00:09–00:11	Mimikatz downloaded from GitHub, extracted, and executed to dump credentials.

Timestamp	Event Description
Aug 30, 00:13	Pass-the-hash attack launched: `sekurlsa::pth /user:itadmin /ntlm:F84769D250EB95EB2D7D8B4A1C5613F2`.
Aug 30, 00:14–00:19	Share enumeration (`Invoke-ShareFinder`), access to remote file `IT_Automation.ps1` revealing credentials `quicklogistics\allan.smith:Tr!ckyP@ssw0rd987`.
Aug 30, 00:20–00:21	Lateral movement to `WKSTN-1327` using stolen credentials (WinRM - `wsmprovhost.exe`).
Aug 30, 01:28–01:30	On `WKSTN-1327`, attacker downloaded Mimikatz, dumped hashes, obtained administrator hash `00f80f2538dcb54e7adc715c0e7091ec`.
Aug 30, 01:35–01:36	DCSync attack on DC01 targeting `administrator` and `backupda` accounts.
Aug 30, 01:42–01:45	Scheduled task `Updater` created on `WKSTN-1327` for fileless persistence (registry-decoded PowerShell).
Aug 30, 01:53–01:57	Ransomware binary `ransomboogey.exe` downloaded from `http://ff.sillytechninja.io/ransomboogey.exe` and executed on multiple hosts (`DC01`, `WKSTN-1327`, `WKSTN-0051`).

3. Detailed Findings

3.1 Initial Access (ISO + HTA)

- **Initial payload:** ISO file attached to phishing email, mounted as `D:\`.
- **Execution:** `mshta.exe` (PID 6392) launched `D:\ProjectFinancialSummary_Q3.pdf.hta`.
- **Stage 1 actions:** Copied `review.dat` to `%TEMP%` using `xcopy`, then executed it via `rundll32.exe`.

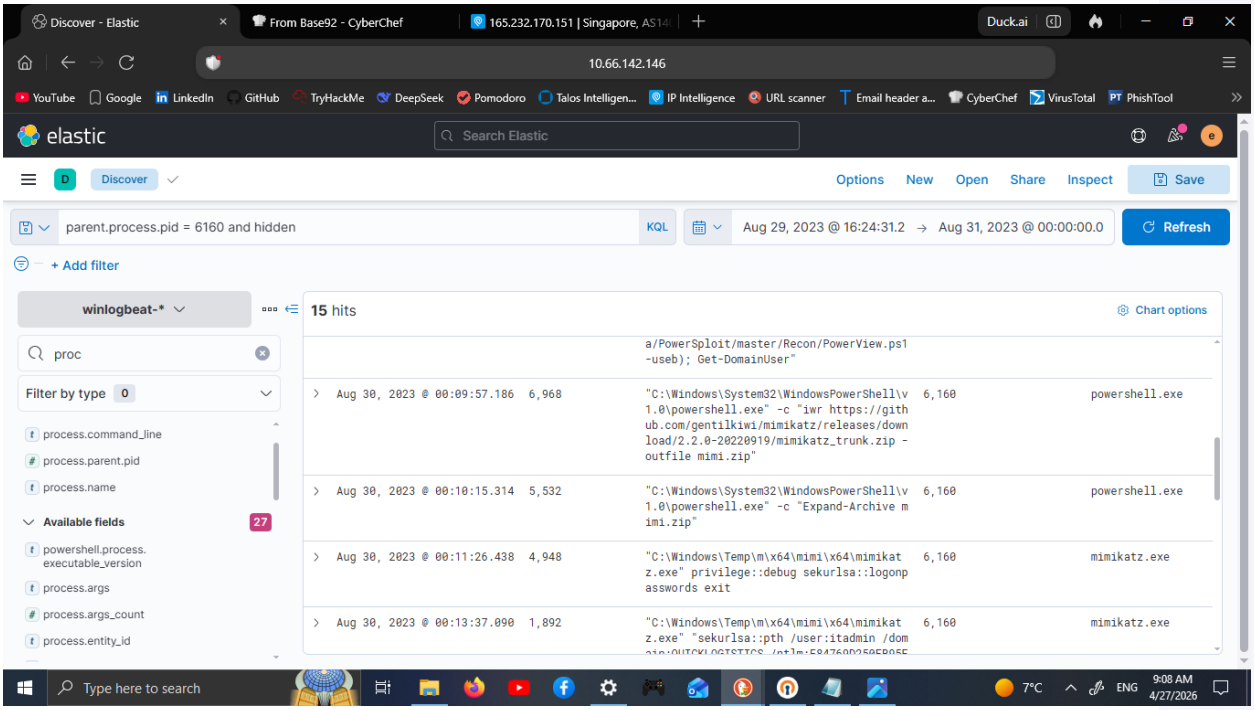


3.2 Persistence

- **Scheduled task:** `Review` (daily at 06:00) – runs `rundll32.exe C:\Users\EVAN~1.HUT\AppData\Local\Temp\review.dat,DllRegisterServer`.
- **Later persistence:** Another scheduled task `Updater` on `WKSTN-1327` using registry-decoded PowerShell (fileless).

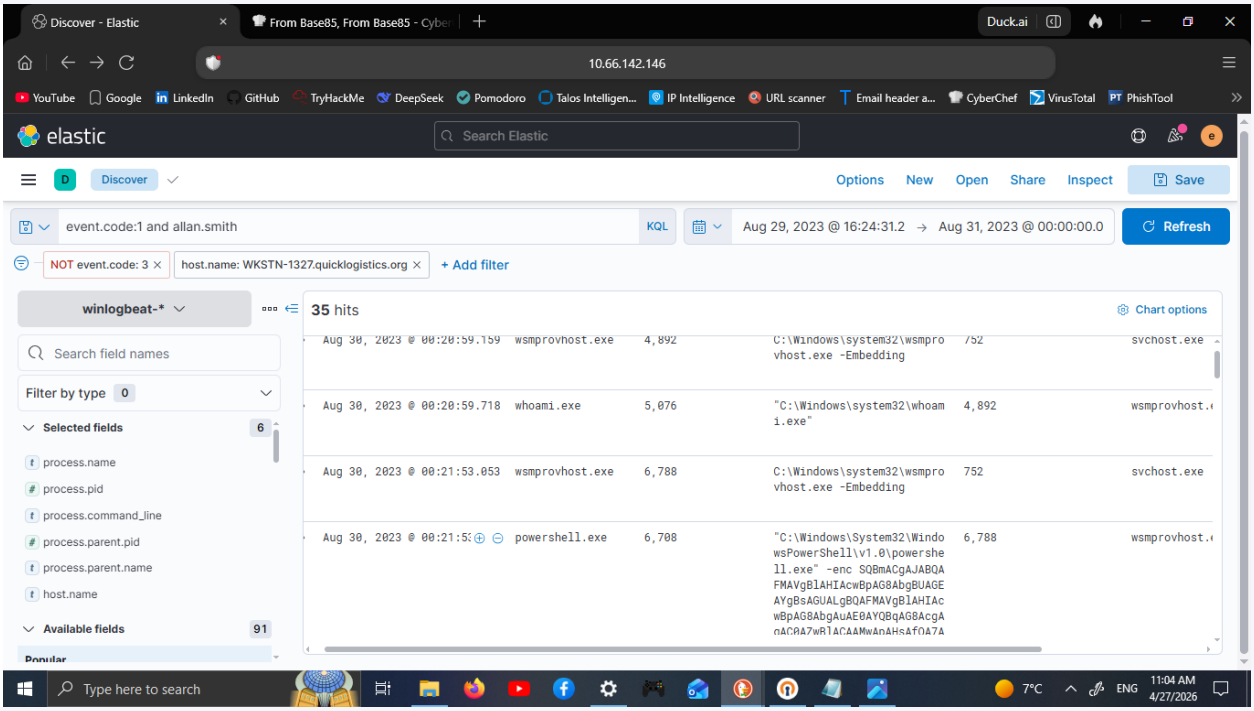
3.3 Discovery & Privilege Escalation

- **UAC bypass:** `fodhelper.exe` launched encoded PowerShell.
- **Reconnaissance:** `whoami /all`, PowerView (`Get-DomainComputer`, `Get-DomainUser`).
- **Credential dumping (initial host):** Downloaded Mimikatz, dumped hashes, obtained `itadmin:NTLM`.



3.4 Lateral Movement

- **Pass-the-hash:** Used `itadmin` hash to launch PowerShell on remote host via `sekurlsa::pth`.
- **WinRM:** `wsmprovhost.exe` parent process on `WKSTN-1327` for lateral execution.
- **Share enumeration:** `Invoke-ShareFinder` discovered `ITFiles` share; read `IT_Automation.ps1` revealing plaintext credentials for `allan.smith`.
- **Second lateral hop:** Used `allan.smith` credentials to move to `WKSTN-1327` and later to `DC01`.

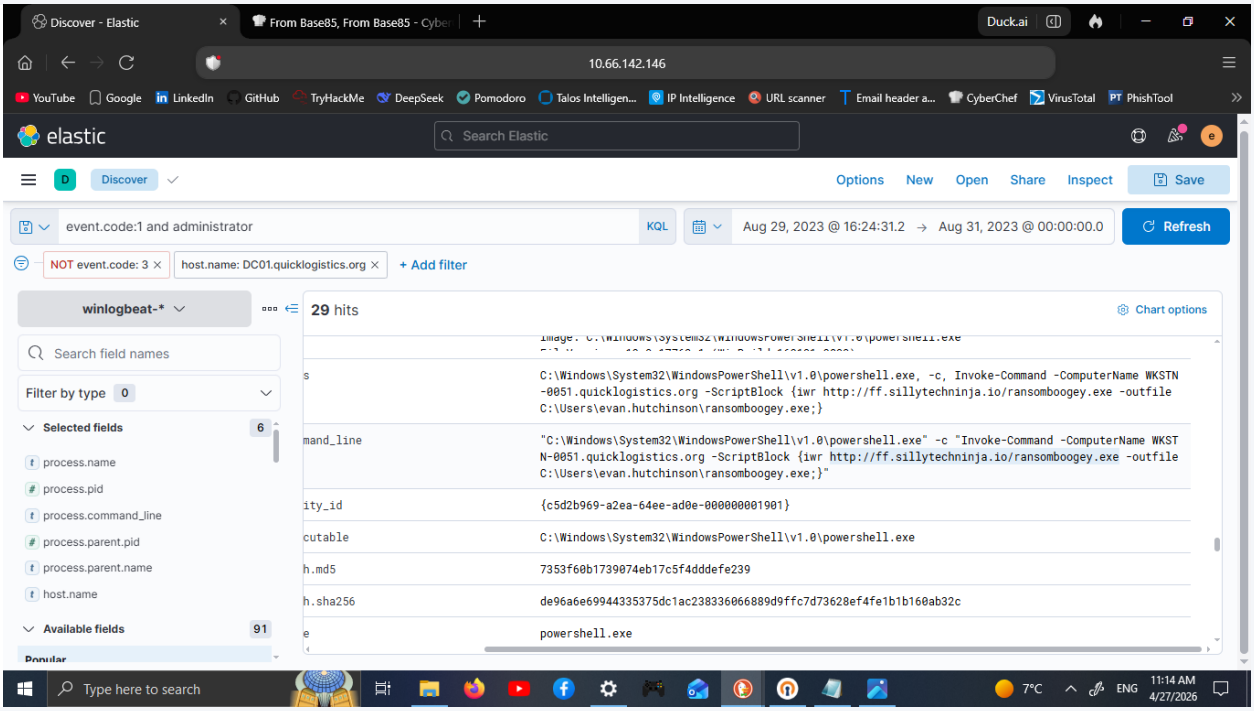


3.5 DCSync & Domain Compromise

- On `DC01`, attacker ran Mimikatz with `lsadump::dcsync` to extract NTLM hashes of `administrator` and `backupda`.
- DCSync succeeded due to high privileges (likely domain admin).

3.6 Ransomware Deployment

- Attacker downloaded `ransomboogey.exe` from malicious URL: `http://ff.sillytechninja.io/ransomboogey.exe`.
- Executed ransomware on `DC01`, `WKSTN-1327`, and `WKSTN-0051` via PowerShell `Invoke-Command`.
- No encryption confirmed in logs, but binary execution indicates attempted impact.



4. Indicators of Compromise (IOCs)

Type	Value
Initial payload (HTA)	`D:\ProjectFinancialSummary_Q3.pdf.hta`
Dropped DLL	`review.dat` (renamed DLL)
Scheduled task names	`Review`, `Updater`

Type	Value
C2 domain & IP	`cdn.bananapeelparty.net` → `165.232.170.151:80`
UAC bypass binary	`fodhelper.exe`
GitHub URL (Mimikatz)	`https://github.com/gentilkiwi/mimikatz/releases/download/2.2.0-20220919/mimikatz_trunk.zip`
Stolen NTLM hashes	`itadmin:F84769D250EB95EB2D7D8B4A1C5613F2` `administrator:00f80f2538dcb54e7adc715c0e7091ec`
Plaintext credential	`QUICKLOGISTICS\allan.smith:Tr!ckyP@ssw0rd987`
Ransomware URL	`http://ff.sillytechninja.io/ransomboogey.exe`
Target hosts	`WKSTN-0051`, `WKSTN-1327`, `DC01`

5. Recommendations

1. **Immediate containment:** Isolate `DC01`, `WKSTN-1327`, `WKSTN-0051`; disable compromised accounts (`itadmin`, `allan.smith`, and rotate credentials for all domain admins).
2. **Remove persistence:** Delete scheduled tasks `Review` and `Updater` from all affected hosts; remove registry persistence keys (`HKCU:\Software\Microsoft\Windows\CurrentVersion\debug` and `HKLM:\Software\Microsoft\Network\debug`).
3. **Network blocks:** Block domains `bananapeelparty.net`, `sillytechninja.io` and IP `165.232.170.151`.
4. **Enhance monitoring:** Enable PowerShell Script Block Logging (Event ID 4104) and monitor for `fodhelper.exe` executions, unusual `wsmprovhost.exe` parents, and DCSync attempts (Event ID 4662).
5. **Security hardening:** Disable WinRM if not required, restrict use of `fodhelper.exe` via AppLocker, enforce LAPS for local admin passwords, and implement Credential Guard.
6. **User education:** Reinforce not opening ISO attachments or enabling macros from untrusted sources.

6. Conclusion

The final Boogeyman attack demonstrates a sophisticated, multi-phase attack chain: spear-phishing with ISO/HTA → persistence → UAC bypass → credential dumping → pass-the-hash → lateral movement → DCSync → ransomware deployment. The attacker successfully compromised the domain controller and attempted to encrypt multiple workstations. Full reconstruction of the event timeline was possible through Elastic Stack logs (Sysmon and Windows Event Logs). Immediate remediation steps include containment of affected hosts, credential reset, removal of persistence, and network-level blocking of malicious indicators.

Prepared by: SOC Incident Response Team
Classification: Confidential – Internal Use Only